

BuildWeek_III_Malware_Analysis

Consegna

Scaricare il MALWARE presente in questo link, effettuare un'analisi completa, pulire le tracce e creare un report:

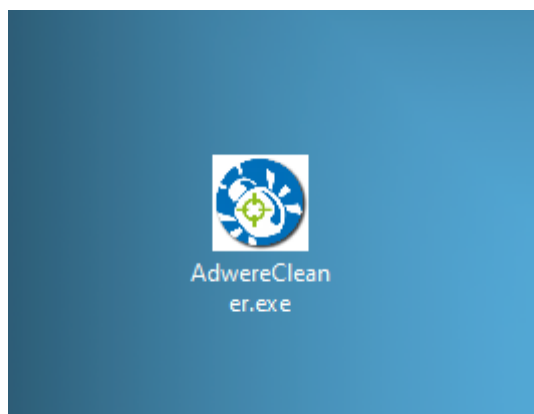
<https://github.com/Da2dalus/The-MALWARERepo/blob/master/roques/AdwereCleaner.exe>

Svolgimento

Environment Set-Up

Ho deciso di esaminare il malware proposto utilizzando una macchina Windows 10 contenente i vari tool appartenenti all **FloreVM**. Ho dunque creato un'istanza per poter ripristinare la macchina nell'eventualità venisse compromessa dall'eseguibile che andrò ad analizzare

Una volta scaricato il malware dal link fornitomi all'interno della traccia ed averne **creato una copia** per preservare l'integrità dell'originale, ho poi provveduto a **disattivare ogni connessione verso la rete esterna internet** per evitare qualsivoglia problematica legata alla successiva esecuzione dell'eseguibile.



Il passo successivo è stato quello di creare una **cartella ambiente isolata** per raccogliere e contenere tutte le evidenze riscontrate durante l'analisi.

Una volta spostato al suo interno il malware, ho poi provveduto ad estrapolare gli hash MD5 e SHA256 per documentare bene il tutto e per usufruirne in eventuali successive analisi tramite motori come VirusTotal:

MD5: 248AADD395FFA7FFB1670392A9398454

:

```
FLARE-VM 09/29/2025 12:25:21
PS C:\Users\User\Desktop\Malwares\BWIII > Get-FileHash -Path "AdwereCleaner.exe" -Algorithm MD5

Algorithm      Hash                                          Path
-----
MD5            248AADD395FFA7FFB1670392A9398454          C:\Users\User\Desktop\Malware...
```

SHA256:

51290129CCCCA38C6E3B4444D0DFB8D848C8F3FC2E5291FC0D219FD642530AD

```
FLARE-VM 09/29/2025 12:25:32
PS C:\Users\User\Desktop\Malwares\BWIII > Get-FileHash -Path "AdwereCleaner.exe" -Algorithm SHA256

Algorithm      Hash                                          Path
-----
SHA256         51290129CCCCA38C6E3B4444D0DFB8D848C8F3FC2E5291FC0D219FD642530ADC C:\Users\User\Desktop\Malware...
```

I due hashes sono stati salvati all'interno di un file di testo chiamato **hashes.txt**:

 *hashes.txt - Blocco note di Windows

File	Modifica	Formato	Visualizza	?
SHA256		51290129CCCCA38C6E3B4444D0DFB8D848C8F3FC2E5291FC0D219FD642530ADC		
MD5		248AADD395FFA7FFB1670392A9398454		

Analisi Statica

Prima di lanciare l'eseguibile ho deciso di cercare di determinarne il comportamento tramite un'analisi statica.

Ho dunque iniziato ricavando alcuni dati generici tramite **sigcheck**:

C:\Tools\Sysinternals\sigcheck.exe -q -nobanner AdwereCleaner.exe

```

FLARE-VM 29/09/2025 12:41:25,71
C:\Users\User\Desktop\Malwares\BWIII>C:\Tools\Sysinternals\sigscheck.exe -q -nobanner AdwereCleaner.exe
C:\Users\User\Desktop\Malwares\BWIII\AdwereCleaner.exe:
    Verified:      Signed
    Signing date:  22:05 04/02/2015
    Publisher:     WAT Software Rotterdam
    Company:       n/a
    Description:   n/a
    Product:       n/a
    Prod version:  n/a
    File version:  n/a
    MachineType:   32-bit

```

Possiamo quindi determinare che il PE sfrutta **un'architettura a 32-bit**.

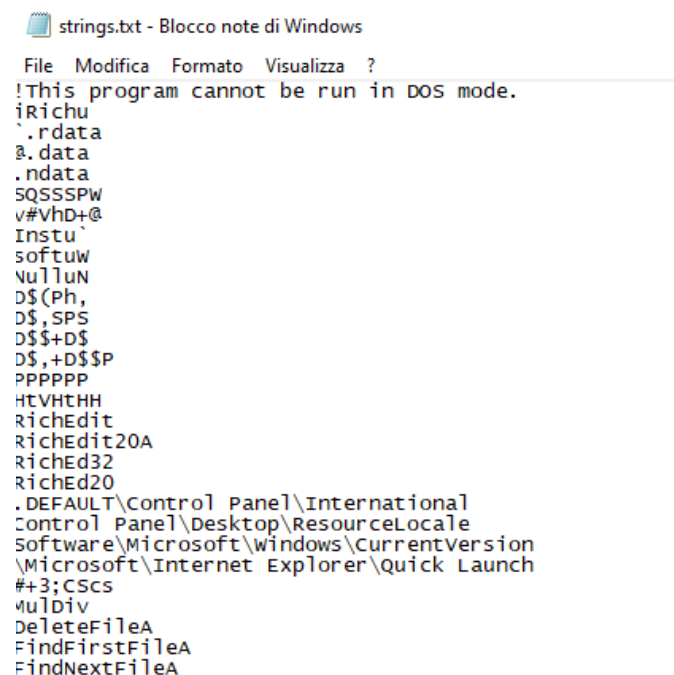
Ho poi deciso di catturare le stringhe leggibili presenti all'interno dell'eseguibile tramite il tool **strings**:

```

C:\Users\User\Desktop\Malwares\BWIII>C:\Tools\Sysinternals\strings.exe -accepteula -n 6 AdwereCleaner.exe > strings.txt

```

Il risultato è stato dunque salvato all'interno del file **strings.txt**.



```

strings.txt - Blocco note di Windows
File  Modifica  Formato  Visualizza  ?
!This program cannot be run in DOS mode.
iRichu
.rdata
.data
.ndata
SQSSSPW
v#VhD+@
Instu
softuw
Nullun
D$(Ph,
D$,SPS
D$$+D$
D$,+D$$P
PPPPPP
HTVHthH
RichEdit
RichEdit20A
RichEd32
RichEd20
.DEFAULT\Control Panel\International
Control Panel\Desktop\ResourceLocale
Software\Microsoft\windows\CurrentVersion
\Microsoft\Internet Explorer\Quick Launch
#+3;CScs
MulDiv
DeleteFileA
FindFirstFileA
FindNextFileA

```

Le evidenze principali sono i marker "Nullsoft Install System v3.0a2", "NSIS Error", "~nsu.tmp", messaggi di "verifying installer...", vari controlli GUI (RichEdit, msctls_progress32, SysListView32) e una import table tipica da installer (KERNEL32/USER32/SHELL32/ADVAPI32, funzioni di file/registo come CreateFileA, RegSetValueExA, MoveFileExA, ExitWindowsEx, SeShutdownPrivilege).

La prossima mossa è consistita nell'avviare **CFF** per reperire informazioni al fine di restringere il campo delle successive analisi:

Analizzando la sezione DOS e Optional Header possiamo determinare quanto segue:

- **e_magic = MZ** → conferma che è un PE valido.
- **PE32** → architettura a 32 bit.
- Entry Point = **0x3E4** → molto vicino all'inizio del file, tipico per un stub (nel tuo caso NSIS installer).
- Subsystem = **Windows GUI** → non è una console app, quindi si presenterà con GUI.
- Checksum presente (**0030F37**) - (dato non affidabile) → tipico nei programmi compilati o compressi.

CFF Explorer VIII - [AdwareCleaner.exe]

Member	Offset	Size	Value
e_magic	00000000	Word	5A4D
e_cblp	00000002	Word	0090
e_cp	00000004	Word	0003
e_crlc	00000006	Word	0000
e_cparhdr	00000008	Word	0004
e_minalloc	0000000A	Word	0000
e_maxalloc	0000000C	Word	FFFF
e_ss	0000000E	Word	0000
e_sp	00000010	Word	00B8
e_csum	00000012	Word	0000
e_ip	00000014	Word	0000
e_cs	00000016	Word	0000
e_lfarlc	00000018	Word	0040
e_ovno	0000001A	Word	0000
e_res	0000001C	Word	0000
	0000001E	Word	0000
	00000020	Word	0000
	00000022	Word	0000
e_oemid	00000024	Word	0000
e_oeminfo	00000026	Word	0000
e_res2	00000028	Word	0000
	0000002A	Word	0000
	0000002C	Word	0000
	0000002E	Word	0000
	00000030	Word	0000
	00000032	Word	0000
	00000034	Word	0000
	00000036	Word	0000
	00000038	Word	0000
	0000003A	Word	0000
e_lfanew	0000003C	Dword	000000C8

CFF Explorer VIII - [AdwareCleaner.exe]

Member	Offset	Size	Value	Meaning
Magic	000000E0	Word	010B	PE32
MajorLinkerVersion	000000E2	Byte	06	
MinorLinkerVersion	000000E3	Byte	00	
SizeOfCode	000000E4	Dword	00005E00	
SizeOfInitializedData	000000E8	Dword	00027C00	
SizeOfUninitializedData	000000EC	Dword	00000400	
AddressOfEntryPoint	000000F0	Dword	000030E4	.text
BaseOfCode	000000F4	Dword	00001000	
BaseOfData	000000F8	Dword	00007000	
ImageBase	000000FC	Dword	00400000	
SectionAlignment	00000100	Dword	00001000	
FileAlignment	00000104	Dword	00000200	
MajorOperatingSystemVersion	00000108	Word	0004	
MinorOperatingSystemVersion	0000010A	Word	0000	
MajorImageVersion	0000010C	Word	0006	
MinorImageVersion	0000010E	Word	0000	
MajorSubsystemVersion	00000110	Word	0004	
MinorSubsystemVersion	00000112	Word	0000	
Win32VersionValue	00000114	Dword	00000000	
SizeOfImage	00000118	Dword	00043000	
SizeOfHeaders	0000011C	Dword	00000400	
Checksum	00000120	Dword	00030F37	
Subsystem	00000124	Word	0002	Windows GUI
DllCharacteristics	00000126	Word	8000	Click here
SizeOfStackReserve	00000128	Dword	00100000	
SizeOfStackCommit	0000012C	Dword	00001000	
SizeOfHeapReserve	00000130	Dword	00100000	
SizeOfHeapCommit	00000134	Dword	00001000	
LoaderFlags	00000138	Dword	00000000	
NumberOfRvaAndSizes	0000013C	Dword	00000010	

Ispezionando le **Section Headers** l'unica attività sospetta è data da **ndata** in quanto non solitamente comune nei PE legittimi. Potrebbe dunque contenere dati temporanei o segmenti usati dall'installer.

CFF Explorer VIII - [AdwereCleaner.exe]

File Settings ?

AdwereCleaner.exe

Name	Virtual Size	Virtual Address	Raw Size	Raw Address	Reloc Address	Linenumbers	Relocations N...	Linenumbers ...	Characteristics
Byte[8]	Dword	Dword	Dword	Dword	Dword	Dword	Word	Word	Dword
.text	00005DE2	00001000	00005E00	00000400	00000000	00000000	0000	0000	60000020
.rdata	000012DA	00007000	00001400	00006200	00000000	00000000	0000	0000	40000040
.data	00025498	00009000	00000400	00007600	00000000	00000000	0000	0000	C0000040
.ndata	00008000	0002F000	00000000	00000000	00000000	00000000	0000	0000	C0000080
.rsrc	0000B268	00037000	0000B400	00007A00	00000000	00000000	0000	0000	40000040

File: AdwereCleaner.exe

- Dos Header
- Nt Headers
- File Header
- Optional Header
- Data Directories [x]
- Section Headers [x]
- Import Directory
- Resource Directory
- Address Converter
- Dependency Walker

Dando un'occhiata alla schermata relativa ad **Import Directory** possiamo trarre i seguenti dati:

Le DLL utilizzate sono DLL standard di sistema: [KERNEL32](#), [USER32](#), [GDI32](#), [SHELL32](#), [ADVAPI32](#), [COMCTL32](#), [ole32](#), [VERSION](#).

Alcune API possono però risultare interessanti:

- **File/Directory:** [CreateFileA](#), [MoveFileA](#), [DeleteFileA](#), [CreateDirectoryA](#), [CopyFileA](#) → **indica capacità di manipolare file.**
- **Registro:** [RegCreateKeyExA](#), [RegSetValueExA](#), [RegDeleteKeyA](#) → **capacità di modificare il registro** (persistenza o configurazioni).
- **Processi/Thread:** [CreateProcessA](#), [CreateThread](#), [WaitForSingleObject](#) → **può avviare altri programmi o gestire thread.**

CFF Explorer VIII - [AdwereCleaner.exe]

File Settings ?

AdwereCleaner.exe

Module Name	Imports	OFIs	TimeDateStamp	ForwarderChain	Name RVA	FTs (IAT)
szAnsi	(nFunctions)	Dword	Dword	Dword	Dword	Dword
KERNEL32.dll	61	000075C4	00000000	00000000	00007C12	00007060
USER32.dll	63	000076D8	00000000	00000000	00008022	00007174
GDI32.dll	8	000075A0	00000000	00000000	000080B4	0000703C
SHELL32.dll	6	000076BC	00000000	00000000	00008140	00007158
ADVAPI32.dll	9	00007564	00000000	00000000	000081E2	00007000
COMCTL32.dll	4	0000758C	00000000	00000000	0000822E	00007028
ole32.dll	4	000077E8	00000000	00000000	00008282	00007284
VERSION.dll	3	000077D8	00000000	00000000	000082CE	00007274

File: AdwereCleaner.exe

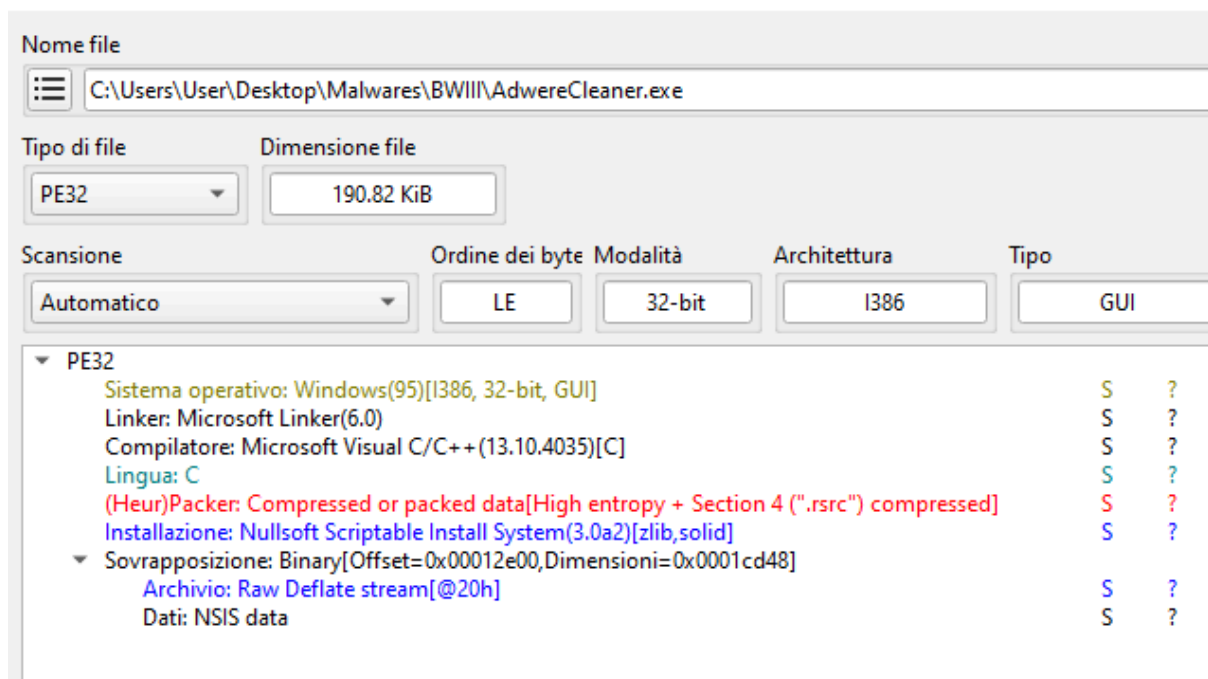
- Dos Header
- Nt Headers
- File Header
- Optional Header
- Data Directories [x]
- Section Headers [x]
- Import Directory
- Resource Directory
- Address Converter
- Dependency Walker
- Hex Editor
- Identifier
- Import Adder
- Quick Disassembler
- Rebuilder
- Resource Editor
- UPX Utility

Per cercare ulteriori informazioni ho poi deciso di lanciare una veloce analisi con DIE - Detect It Easy - grazie alla quale è stato possibile confermare un dato importante: **l'eseguibile è un installer NSIS che presenta istruzioni compresse all'interno dell'overlay.**

Ora sappiamo dunque che, nel caso di azioni malevole, queste saranno svolte in fase di installazione quando il programma decomprimerà il suo payload.

Tale comportamento può però essere osservato solamente procedendo tramite un'**analisi dinamica**.

 Detect It Easy v3.10 [Windows 10 Version 2009] (x86_64)



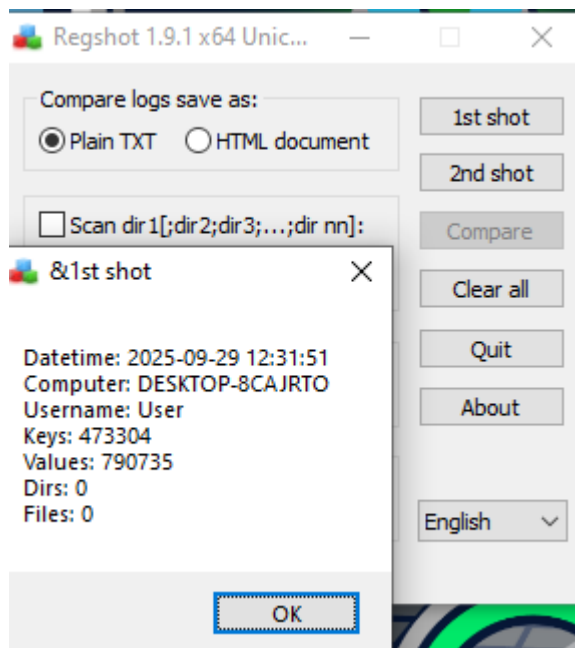
Analisi Dinamica

Preparazione

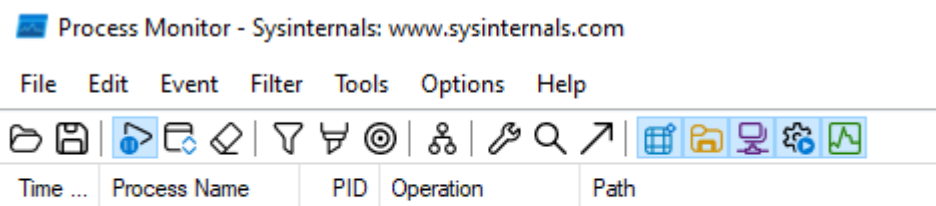
Prima di procedere con l'analisi dinamica è necessario, al fine di registrare cambiamenti significativi, avere una panoramica esatta della situazione del sistema pre-esecuzione del malware.

Per fare ciò ho ritenuto opportuno:

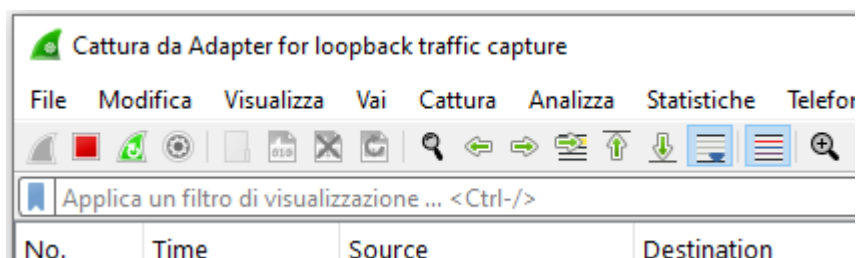
Creare una situazione di registri di windows tramite RegShot:



Avviare Procmon in modalità Monitoring:



Avviare Wireshark in modalità Capture per catturare tentativi di traffico in uscita:



Avvio - GUI

Una volta avviato il programma ci troviamo dinanzi ad un'introduzione nella quale ci viene comunicato che il programma è pensato per ripulire il nostro sistema dalle pubblicità ed i popup che incontriamo navigando il web. Ci comunica poi che AdwCleaner scansionerà il nostro sistema alla ricerca di ogni minaccia presente e, a seguito di ciò, ne procederà alla rimozione rendendo il nostro sistema molto più veloce di quanto non lo sia attualmente.

Ci avverte poi che gli adware e gli spyware sono anche responsabili del furto di dati sensibili come password, dettagli bancari, carte di credito e altro.

Ci lascia poi suggerendoci di eseguire il programma regolarmente.



Una volta avviato lo scan sembra venga avviata una scansione di sistema che ci ritorna, una volta terminata, una serie di presunte criticità che si propone poi di ripulire.



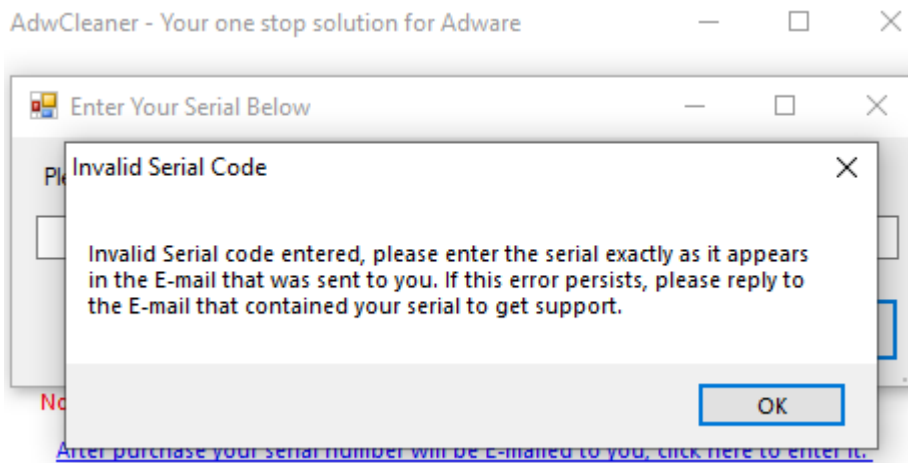
Cliccando su report, ci propone di inviare i risultati della scansione in modo da migliorare il loro servizio di detection futuro:



Procedendo invece su clean ci appare una finestra popup che chiede di acquistare la licenza per proseguire con l'operazione; non v'è però alcuna pagina web alla quale essere rimandati.

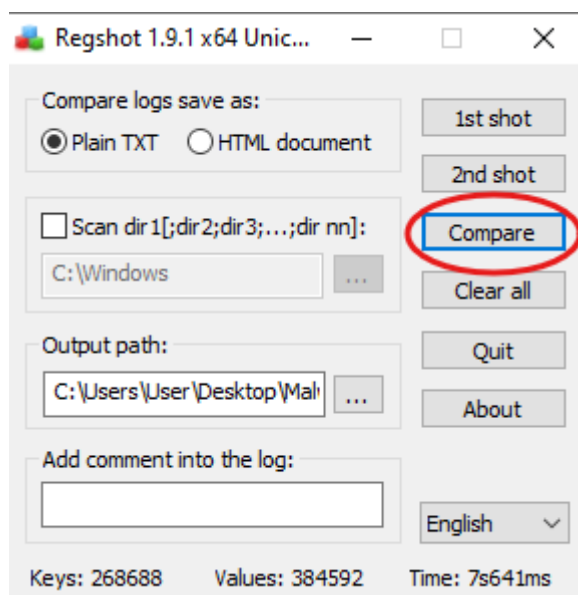


Tentando di inserire una chiave casuale riceviamo un errore:



Analisi RegShot

Concluse le prove con la GUI ho provveduto a creare la seconda immagine di registro e a compararla con quella pre-run.



Tra i risultati emersi, l'unica criticità interessante emersa è la modifica di una chiave di registro che permette ad un software apparentemente sconosciuto di avviarsi automaticamente in seguito ad ogni login:

HKU\S-1-5-21-623064250-797055843-3829581938-1001\Software\Microsoft\Windows\CurrentVersion\Run\AdwCleaner:

"C:\Users\User\AppData\Local\6AdwCleaner.exe" -auto"

9HKU\S-1-5-21-623064250-797055843-3829581938-1001\Software\Microsoft\Windows\CurrentVersion\Explorer\CIDsave\Modules\GlobalSettings\ProperTreeModuleInner\ProperTree
9HKU\S-1-5-21-623064250-797055843-3829581938-1001\Software\Microsoft\Windows\CurrentVersion\Run\AdwCleaner: "C:\Users\User\AppData\Local\6AdwCleaner.exe" -auto
9HKU\S-1-5-21-623064250-797055843-3829581938-1001\Software\Microsoft\Windows NT\CurrentVersion\AppCompatFlags\Compatibility Assistant\Store\C:\Program Files\WinRAR
9HKU\S-1-5-21-623064250-797055843-3829581938-1001\Software\Microsoft\Windows NT\CurrentVersion\AppCompatFlags\Compatibility Assistant\Store\C:\Users\User\Desktop\Mal

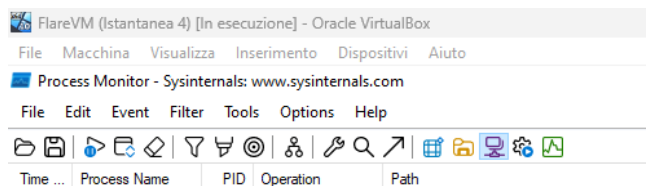
Analisi Wireshark

Il traffico analizzato tramite wireshark è normalissimo traffico di sistema ed è totalmente indipendente da quanto eseguito dal presunto malware.

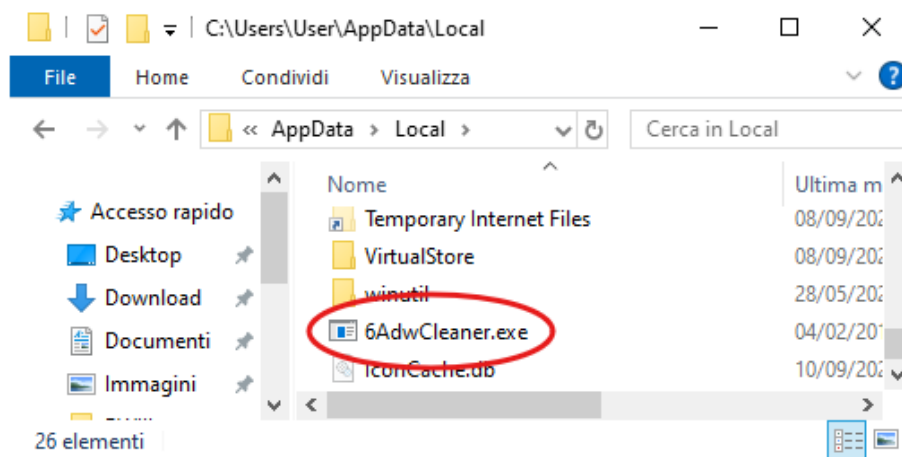
Ciò conferma che probabilmente, come visto nell'assenza di librerie specifiche, il sospetto non tenta collegamenti verso l'esterno.

Analisi Procmon

Dopo aver catturato le varie azioni effettuate dall'eseguibile, possiamo anche in questo caso determinare che AdwCleaner.exe non tenta di stabilire connessioni di rete:



Possiamo però ricavare dai log un'operazione alquanto strana che si ricollega alla chiave precedentemente modificata; il software ha infatti dato vita ad un nuovo eseguibile chiamato **6AdwCleaner.exe**, lo stesso che verrà avviato all'inizio della sessione dell'utente:



```
FLARE-VM 09/29/2025 18:32:03
PS C:\Users\User\AppData\local > Get-FileHash -Path .\6AdwCleaner.exe -Algorithm SHA256

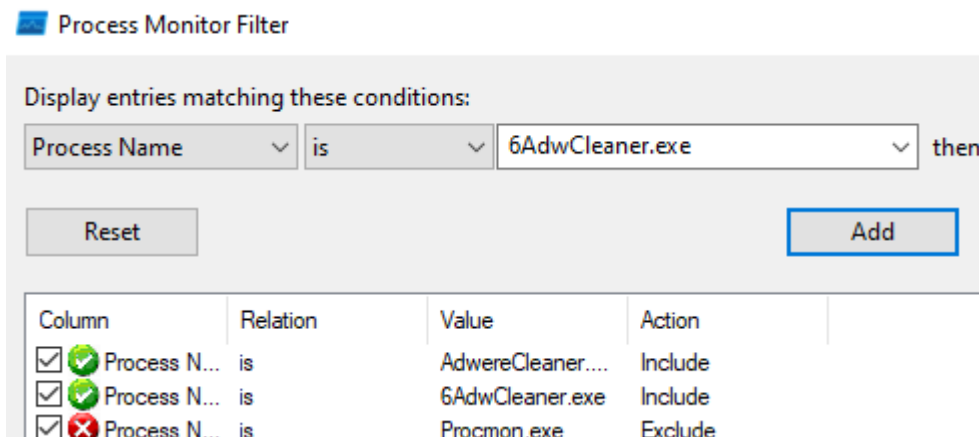
Algorithm      Hash
-----
SHA256         4F0033E811FE2497B38F0D45DF958829D01933EBE7D331079EEFC8E38FBEEA61
C:\Users\User\AppData\local\6...

FLARE-VM 09/29/2025 18:32:50
PS C:\Users\User\AppData\local > Get-FileHash -Path .\6AdwCleaner.exe -Algorithm MD5

Algorithm      Hash
-----
MD5            87E4959FEFEC297EBBF42DE79B5C88F6
C:\Users\User\AppData\local\6...
```

Avendo applicato il filtro solo per il processo padre non è possibile però determinare se e quali operazioni compia tale nuovo eseguibile.

Ho dunque modificato i filtri all'interno di procmon includendo anche questo nuovo processo ed ho rilanciato la scansione ed il primo eseguibile:



In seguito alla nuova analisi, oltre a drop/persistenza, emerge che il payload **6AdwCleaner.exe** scrive nella cache INetCache\IE file come `ErrorPageTemplate[1]`, `dnserroordiagoff[1]`, `navcancl[1]`, `httpErrorPagesScripts[...]`, `fontawesome-webfont.woff2`, `background_gradient[...]`. Questo comportamento è tipico quando un'app con WebBrowser/WinINET tenta di caricare una pagina/risorsa e, senza Internet, ottiene le pagine di errore di IE.

Quindi c'è verosimilmente un **tentativo di contattare risorse web** (pubblicità/C2/landing), che all'interno della rete isolata non appare come traffico utile ma lascia cache locale.

FakeNet

Una volta venuto a conoscenza dei tentativi di connessione verso l'esterno, ho deciso di simulare una rete per catturare tutte le richieste eseguite dai due payloads.

Ho dunque avviato FakeNet ed ho eseguito nuovamente il primo file. In seguito a ciò riusciamo a confermare che tutto il "lavoro sporco" viene però svolto dall'eseguibile figlio.

```
09/29/25 05:04:58 PM [ Diverter] 6AdwCleaner.exe (2660) requested UDP 10.0.2.15:53
09/29/25 05:04:58 PM [ DNS Server] Received A request for domain 'www.vikingwebscanner.com' from 6AdwCleaner.exe (2660)
09/29/25 05:04:58 PM [ DNS Server] Received AAAA request for domain 'www.vikingwebscanner.com' from 6AdwCleaner.exe (2660)
09/29/25 05:04:58 PM [ Diverter] 6AdwCleaner.exe (2660) requested TCP 192.0.2.123:80
09/29/25 05:04:58 PM [ HTTPListener80] GET /scripts/status.php?action=renew&id=0 HTTP/1.1
09/29/25 05:04:58 PM [ HTTPListener80] Host: www.vikingwebscanner.com
09/29/25 05:04:58 PM [ HTTPListener80] Connection: Keep-Alive
09/29/25 05:04:58 PM [ HTTPListener80]
09/29/25 05:05:03 PM [ HTTPListener80] GET /scripts/status.php?action=scan&id=0 HTTP/1.1
09/29/25 05:05:03 PM [ HTTPListener80] Host: www.vikingwebscanner.com
09/29/25 05:05:03 PM [ HTTPListener80] Connection: Keep-Alive
09/29/25 05:05:03 PM [ HTTPListener80]
09/29/25 05:05:03 PM [ HTTPListener80]
```

Dai log ottenuti possiamo riscontrare quanto segue:

6AdwCleaner.exe risolve, tramite richieste A e AAAA, **www.vikingwebscanner.com** e stabilisce connessioni TCP su **192.0.2.123:80**. Le richieste **GET HTTP** registrate sono coerenti con un **scareware/adware** che esegue operazioni di reporting/scan e richieste di pagamento:

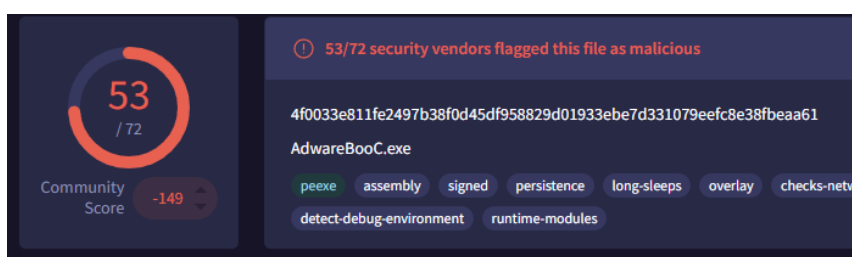
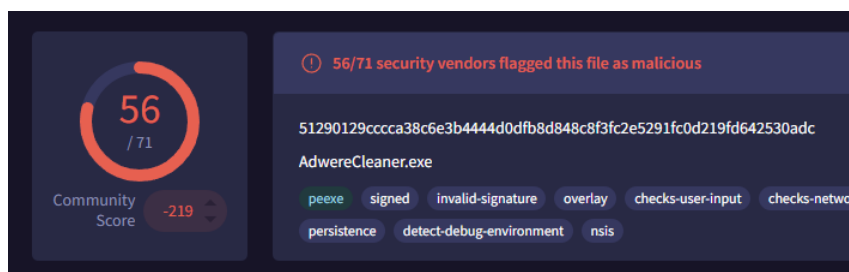
- `/scripts/paymore.php`
- `/scripts/status.php?action=clean&id=0`
- `/scripts/status.php?action=renew&id=0`
- `/scripts/status.php?action=scan&id=0`
- `/scripts/get_data.php?id=0`
- `/scripts/paydefault.php?id=0`

Notiamo anche che l'eseguibile utilizza come **User-Agent** quello di **Internet Explorer 7/Trident**, arricchito da riferimenti al **.NET CLR**.

Questo stratagemma è tipico dei software ingannevoli, che cercano di camuffare il proprio traffico come legittimo o di apparire come un programma Windows autentico, spesso facendo riferimento a tecnologie datate per sembrare più credibili.

Indicatori di Compromissione (IOC):

- Hash:
 - AdwereCleaner.exe MD5: 248AADD395FFA7FFB1670392A9398454
 - AdwereCleaner.exe SHA256:
51290129CCCCA38C6E3B4444D0DFB8D848C8F3FC2E5291FC0D219FD642530AD
 - 6AdwCleaner.exe MD5: 87E4959FEFEC297EBBF42DE79B5C88F6
 - 6AdwCleaner.exe SHA256:
4F0033E811FE2497B38F0D45DF958829D01933EBE7D331079EEFC8E38FBEEA61
- File drop:
 - %AppData%\Local\6AdwCleaner.exe
- Registry persistence:
 - HKU\...\CurrentVersion\Run\AdwCleaner =
"C:\Users\User\AppData\Local\6AdwCleaner.exe" -auto
- Network:
 - Dominio: www.vikingwebscanner.com
 - URL: /scripts/paymore.php, /scripts/paydefault.php, /scripts/status.php, /scripts/get_data.php



AhnLab-V3	Trojan:Win32.FakeAV.C759807	Alibaba	Hoax:MSIL/FakeAV.F9f839c3
AliCloud	Trojan:MSIL/Hoax.Akgpp	ALYac	Gen:Variant.Jatiff.308
Antiy-AVL	HackTool[Hoax]/MSIL.Agent	Arcabit	Trojan.Jatiff.308
Avast	Win32:FakeAV-FLW [Trj]	AVG	Win32:FakeAV-FLW [Trj]

Conclusioni

L'analisi condotta dimostra che l'eseguibile analizzato non è un vero strumento di pulizia, bensì un **fake AdwCleaner** appartenente alla categoria degli **scareware/adware**. Il suo obiettivo non è migliorare le prestazioni del sistema, ma ingannare l'utente attraverso una finta scansione che segnala problemi inesistenti.

Il comportamento malevolo osservato si articola in tre punti principali:

1. **Persistenza:** il malware crea e registra un file figlio - **6AdwCleaner.exe** - nella cartella **%AppData%\Local**, aggiungendolo alla chiave di registro **Run** per garantirne l'avvio automatico a ogni login.
2. **Comunicazione esterna:** tramite l'eseguibile figlio tenta di collegarsi al dominio **www.vikingwebscanner.com**, inviando richieste HTTP verso script PHP come **status.php**, **get_data.php** e **paymore.php**. Tali richieste suggeriscono un modello di monetizzazione basato sullo scareware: generare falsi allarmi e spingere l'utente a un pagamento.
3. **Social engineering:** la GUI del programma imita un software di sicurezza, mostra avvisi ingannevoli e propone la "pulizia" del sistema solo dopo l'acquisto di una licenza, **sfruttando il timore dell'utente**.

Non sono state rilevate attività tipiche di malware più distruttivi, come cifratura di file o esfiltrazione di dati sensibili. Tuttavia, la natura ingannevole e persistente del software lo rende pericoloso, in quanto **può indurre la vittima a eseguire ulteriori download o a effettuare pagamenti non legittimi**.

In sintesi, questo malware è un esempio di **rogue security software**, la cui finalità principale è trarre profitto tramite l'inganno piuttosto che danneggiare direttamente il sistema.